

Comments and Response submitted by:

Gaurav Pal

Principal, stackArmor, Inc.

Questions

AI Accountability Objectives

1. What is the purpose of AI accountability mechanisms such as certifications, audits, and assessments?

Responses could address the following:

a. What kinds of topics should AI accountability mechanisms cover? How should they be scoped?

The AI accountability mechanisms should cover people, processes, technology and data elements. One approach for scoping is to leverage the NIST SP 800-53 with the additional privacy overlays and NIST SP 800-37. These artifacts could be useful starting points to help organizations develop mechanisms for AI accountability.

b. What are assessments or internal audits most useful for? What are external assessments or audits most useful for?

c. An audit or assessment may be used to verify a claim, verify compliance with legal standards, or assure compliance with non-binding trustworthy AI goals. Do these differences impact how audits or assessments are structured, credentialed, or communicated?

d. Should AI audits or assessments be folded into other accountability mechanisms that focus on such goals as human rights, privacy protection, security, and diversity, equity, inclusion, and access? Are there benchmarks for these other accountability mechanisms that should inform AI accountability measures?

e. Can AI accountability practices have meaningful impact in the absence of legal standards and enforceable risk thresholds? What is the role for courts, legislatures, and rulemaking bodies?

2. Is the value of certifications, audits, and assessments mostly to promote trust for external stakeholders or is it to change internal processes? How might the answer influence policy design?

3. AI accountability measures have been proposed in connection with many different goals, including those listed below. To what extent are there tradeoffs among these goals? To what extent can these inquiries be conducted by a single team or instrument?

a. The AI system does not substantially contribute to harmful discrimination against people.

b. The AI system does not substantially contribute to harmful misinformation, disinformation, and other forms of distortion and content-related harms.

c. The AI system protects privacy.

d. The AI system is legal, safe, and effective.

e. There has been adequate transparency and explanation to affected people about the uses, capabilities, and limitations of the AI system.

f. There are adequate human alternatives, consideration, and fallbacks in place throughout the AI system lifecycle.

g. There has been adequate consultation with, and there are adequate means of contestation and redress for, individuals affected by AI system outputs.

h. There is adequate management within the entity deploying the AI system such that there are clear lines of responsibility and appropriate skillsets.

4. Can AI accountability mechanisms effectively deal with systemic and/or collective risks of harm, for example, with respect to worker and workplace health and safety, the health and safety of marginalized communities, the democratic process, human autonomy, or emergent risks?

5. Given the likely integration of generative AI tools such as large language models (e.g., ChatGPT) or other general-purpose AI or foundational models into downstream products, how can AI accountability mechanisms inform people about how such tools are operating and/or whether the tools comply with standards for trustworthy AI? (80)

6. The application of accountability measures (whether voluntary or regulatory) is more straightforward for some trustworthy AI goals than for others. With respect to which trustworthy AI goals are there existing requirements or standards? Are there any trustworthy AI goals that are not amenable to requirements or standards? How should accountability policies, whether governmental or non-governmental, treat these differences?

7. Are there ways in which accountability mechanisms are unlikely to further, and might even frustrate, the development of trustworthy AI? Are there accountability mechanisms that unduly impact AI innovation and the competitiveness of U.S. developers?

8. What are the best definitions of and relationships between AI accountability, assurance, assessments, audits, and other relevant terms?

All of the terms mentioned above are part of AI Risk Management. The AI Risk Management Framework (NIST AI RMF) provides definitions for some of these terms especially when mapped to NIST SP 800-53 and NIST SP 800-37. By leveraging existing definitions and relationships, we can accelerate the development of a framework and promote understanding.

Existing Resources and Models

9. What AI accountability mechanisms are currently being used? Are the accountability frameworks of certain sectors, industries, or market participants especially mature as compared to others? Which industry, civil society, or governmental accountability instruments, guidelines, or policies are most appropriate for implementation and operationalization at scale in the United States? Who are the people currently doing AI accountability work?

10. What are the best definitions of terms frequently used in accountability policies, such as fair, safe, effective, transparent, and trustworthy? Where can terms have the same meanings across sectors and jurisdictions? Where do terms necessarily have different meanings depending on the jurisdiction, sector, or use case?

11. What lessons can be learned from accountability processes and policies in cybersecurity, privacy, finance, or other areas? (81)

There are a number of models and frameworks such as FedRAMP and StateRAMP in the cybersecurity and commercial cloud services area. Additionally, security controls-based standards and guidance like NIST SP 800-53 and NIST SP 800-37. AI accountability without the appropriate enforcement and regulatory framework will not likely drive investment, change and meaningful accountability

mechanisms. Another regulatory framework and model that might be considered is from the finance world – Broker dealers are regulated by Financial Industry Regulatory Authority (FINRA). FINRA is a industry regulator with oversight from the SEC.

12. What aspects of the United States and global financial assurance systems provide useful and achievable models for AI accountability?

13. What aspects of human rights and/or industry Environmental, Social, and Governance (ESG) assurance systems can and should be adopted for AI accountability?

14. Which non-U.S. or U.S. (federal, state, or local) laws and regulations already requiring an AI audit, assessment, or other accountability mechanism are most useful and why? Which are least useful and why?

Accountability Subjects

15. The AI value or supply chain is complex, often involving open source and proprietary products and downstream applications that are quite different from what AI system developers may initially have contemplated. Moreover, training data for AI systems may be acquired from multiple sources, including from the customer using the technology. Problems in AI systems may arise downstream at the deployment or customization stage or upstream during model development and data training.

a. Where in the value chain should accountability efforts focus?

b. How can accountability efforts at different points in the value chain best be coordinated and communicated?

c. How should vendors work with customers to perform AI audits and/or assessments? What is the role of audits or assessments in the commercial and/or public procurement process? Are there specific practices that would facilitate credible audits (e.g., liability waivers)?

d. Since the effects and performance of an AI system will depend on the context in which it is deployed, how can accountability measures accommodate unknowns about ultimate downstream implementation?

16. The lifecycle of any given AI system or component also presents distinct junctures for assessment, audit, and other measures. For example, in the case of bias, it has been shown that “[b]ias is prevalent in the assumptions about which data should be used, what AI models should be developed, where the AI system should be placed—or if AI is required at all.” (82) How should AI accountability mechanisms consider the AI lifecycle? Responses could address the following:

a. Should AI accountability mechanisms focus narrowly on the technical characteristics of a defined model and relevant data? Or should they feature other aspects of the socio- technical system, including the system in which the AI is embedded? (83) When is the narrower scope better and when is the broader better? How can the scope and limitations of the accountability mechanism be effectively communicated to outside stakeholders?

b. How should AI audits or assessments be timed? At what stage of design, development, and deployment should they take place to provide meaningful accountability?

Based on the lessons learned from IT Systems, it is important to time the assessments such that they occur during the development process prior to production release and then on an ongoing basis. The development of a strong continuous monitoring is critical. NIST publications such as NIST SP 800-137 can provide an initial basis for helping develop a audit and assessment framework.

c. How often should audits or assessments be conducted, and what are the factors that should inform this decision? How can entities operationalize the notion of continuous auditing and communicate the results?

d. What specific language should be incorporated into governmental or non-governmental policies to secure the appropriate timing of audits or assessments?

17. How should AI accountability measures be scoped (whether voluntary or mandatory) depending on the risk of the technology and/or of the deployment context? If so, how should risk be calculated and by whom?

18. Should AI systems be released with quality assurance certifications, especially if they are higher risk?

19. As governments at all levels increase their use of AI systems, what should the public expect in terms of audits and assessments of AI systems deployed as part of public programs? Should the accountability practices for AI systems deployed in the public sector differ from those used for private sector AI? How can government procurement practices help create a productive AI accountability ecosystem?

Accountability Inputs and Transparency

20. What sorts of records (e.g., logs, versions, model selection, data selection) and other documentation should developers and deployers of AI systems keep in order to support AI accountability? (84) How long should this documentation be retained? Are there design principles (including technical design) for AI systems that would foster accountability-by-design?

21. What are the obstacles to the flow of information necessary for AI accountability either within an organization or to outside examiners? What policies might ease researcher and other third-party access to inputs necessary to conduct AI audits or assessments?

22. How should the accountability process address data quality and data voids of different kinds? For example, in the context of automated employment decision tools, there may be no historical data available for assessing the performance of a newly deployed, custom-built tool. For a tool deployed by other firms, there may be data a vendor has access to, but the audited firm itself lacks. In some cases, the vendor itself may have intentionally limited its own data collection and access for privacy and security purposes. How should AI accountability requirements or practices deal with these data issues? What should be the roles of government, civil society, and academia in providing useful data sets (synthetic or otherwise) to fill gaps and create equitable access to data?

23. How should AI accountability “products” (e.g., audit results) be communicated to different stakeholders? Should there be standardized reporting within a sector and/or across sectors? How should the translational work of communicating AI accountability results to affected people and communities be done and supported?

Barriers to Effective Accountability

24. What are the most significant barriers to effective AI accountability in the private sector, including barriers to independent AI audits, whether cooperative or adversarial? What are the best strategies and interventions to overcome these barriers?

25. Is the lack of a general federal data protection or privacy law a barrier to effective AI accountability?

26. Is the lack of a federal law focused on AI systems a barrier to effective AI accountability?

27. What is the role of intellectual property rights, terms of service, contractual obligations, or other legal entitlements in fostering or impeding a robust AI accountability ecosystem? For example, do nondisclosure agreements or trade secret protections impede the assessment or audit of AI systems and processes? If so, what legal or policy developments are needed to ensure an effective accountability framework?

28. What do AI audits and assessments cost? Which entities should be expected to bear these costs? What are the possible consequences of AI accountability requirements that might impose significant costs on regulated entities? Are there ways to reduce these costs? What are the best ways to consider costs in relation to benefits?

29. How does the dearth of measurable standards or benchmarks impact the uptake of audits and assessments?

AI Accountability Policies

30. What role should government policy have, if any, in the AI accountability ecosystem? For example: a. Should AI accountability policies and/or regulation be sectoral or horizontal, or some combination of the two?

Given that AI systems will proliferate across the economy, a model that classifies AI systems by criticality offers the ability to develop an AI accountability ecosystem. DHS CISA has identified 16 critical infrastructure sectors, which allow designated a regulator and associated regulatory framework.

b. Should AI accountability regulation, if any, focus on inputs to audits or assessments (e.g., documentation, data management, testing and validation), on increasing access to AI systems for auditors and researchers, on mandating accountability measures, and/or on some other aspect of the accountability ecosystem?

c. If a federal law focused on AI systems is desirable, what provisions would be particularly important to include? Which agency or agencies should be responsible for enforcing such a law, and what resources would they need to be successful?

A mandatory governance and oversight model driven by audits and assessments that are ultimately overseen by a Federal agency has the best likelihood of success. Given that AI systems will proliferate across the economy, a model that classifies AI systems by criticality offers the ability to develop an AI accountability ecosystem. DHS CISA has identified 16 critical infrastructure sectors, which allow designated a regulator and associated regulatory framework. AI systems based on the sector they fall under, they could be regulated by the agency responsible for that sector. However, it is critical that every agency follow and implement a common standard ideally based on a NIST framework or standard to reduce duplication.

d. What accountability practices should government (at any level) itself mandate for the AI systems the government uses?

AI systems used by the government should ensure that they comply with a common standard. In many ways the FISMA law and the NIST RMF (Risk Management Framework) as well as the NIST SP 800-53 security controls baselines are relevant starting points for an accountability framework.

31. What specific activities should government fund to advance a strong AI accountability ecosystem?

32. What kinds of incentives should government explore to promote the use of AI accountability measures?

33. How can government work with the private sector to incentivize the best documentation practices?

34. Is it important that there be uniformity of AI accountability requirements and/or practices across the United States? Across global jurisdictions? If so, is it important only within a sector or across sectors? What is the best way to achieve it? Alternatively, is harmonization or interoperability sufficient and what is the best way to achieve that?